Botium Toys - Controls and Compliance Assessment

Google Cybersecurity Professional Certificate - Portfolio Activity

Assessment based on the Botium Toys scope, goals, and risk assessment report. 'Yes' means the control or best practice is currently in place; 'No' means it is missing or not sufficiently implemented.

1. Controls Assessment Checklist

Security Control	Yes	No	Rationale
Least Privilege		X	Not implemented.
Disaster Recovery Plans		X	No disaster recovery plan is in place.
Password Policies	X		A password policy exists, but its requirements are too weak.
Separation of Duties		X	Not implemented.
Firewall	X		A firewall is in place.
Intrusion Detection System (IDS)		X	No IDS is installed.
Backups		X	There are no backups of critical data.
Antivirus Software	X		Installed and regularly monitored.
Legacy-System Monitoring and Maintenance	X		Legacy systems are monitored and maintained, but there is no fixed schedule.
Encryption		X	Customer credit card data is not currently encrypted.
Password Management System		X	No centralized password management system is in place.
Locks	X		Adequate locks are in place for offices, the storefront, and the warehouse.
CCTV Surveillance	X		Video surveillance is in place.
Fire Detection / Prevention	X		Fire detection and prevention systems are in place.

2. PCI DSS Compliance

Payment Card Industry Data Security Standard

Best Practice	Yes	No
Only authorized users have access to customers' credit card information.		X
Credit card information is stored, accepted, processed, and transmitted internally in a secure environment.		X
Data encryption procedures are implemented to better secure credit card transaction touchpoints and data.		X
Secure password management policies are adopted.		X

3. GDPR Compliance

General Data Protection Regulation (GDPR)

Best Practice	Yes	No
E.U. customers' data is kept private and secure.		X
A plan is in place to notify E.U. customers within 72 hours if their data is compromised or a breach occurs.	X	
Data is properly classified and inventoried.		X
Privacy policies, procedures, and processes are enforced to properly document and maintain data.	X	

4. SOC Type 1 / Type 2 Compliance

Best Practice	Yes	No
User access policies are established.		X
Sensitive data (PII/SPII) is kept confidential and private.		X
Data integrity ensures that data is consistent, complete, accurate, and validated.	X	
Data is available to individuals who are authorized to access it.	X	

5. Recommendations

Botium Toys should take several steps to improve its IT security. First, employees should only have access to the information and systems they actually need for their work. Important responsibilities should also be divided between different employees to reduce security risks.

The company should also encrypt sensitive data, use a system to detect suspicious activity, and regularly back up important files. A disaster recovery plan is also important so that the company can restore its systems after a technical failure or cyberattack.

In addition, Botium Toys should introduce a centralized password management system, create stronger password policies, and improve how it manages and protects its IT assets. It should also ensure that only authorized employees can access sensitive data and systems.

Key Risks

The largest gaps are in access controls, encryption, intrusion detection, backups, disaster recovery, password management, and asset management.